PEVN — BANCO DE PREGUNTAS Y RESPUESTAS GUBERNAMENTALES (Q&A)

RESPUESTAS TÉCNICAS Y FACTUALES PARA AUTORIDADES EVALUADORAS (FASE 0.1)

Destinatarios: Ministerio de Educación Nacional (MEN), MinTIC, Secretarías de Educación, Comités Evaluadores y Órganos de Control

Principio Fundamental: Cero respuestas evasivas o especulativas. Cada respuesta distingue estrictamente lo **verificado empíricamente** de las **decisiones institucionales pendientes**.

Fecha: 21 de Septiembre de 2026

Carácter: Read-Only Factual Evidence

---

1. Categoría: PRODUCTO (Product)

Q-PROD-01: ¿Qué es exactamente PEVN?

- **Respuesta Factual:** Es una plataforma web integral de gestión académica, pedagógica, convivencial y de aulas virtuales diseñada específicamente para los colegios oficiales de Colombia. Integra en una única base de datos multi-inquilino la estructura de sedes DANE, matrícula SIMAT, asignación docente, Sistema Institucional de Evaluación (SIEE, Decreto 1290/2009), observador de convivencia (Ley 1620/2013), circulares oficiales y portales independientes para directivos, docentes, estudiantes y familias.
- **Lo que SÍ hace hoy:** Gestiona la jornada escolar completa de 8 roles institucionales, asienta calificaciones híbridas con justificación docente obligatoria, registra asistencias, recibe tareas y evidencias digitales, tipifica faltas de convivencia y registra acuses electrónicos de circulares.
- **Lo que NO hace hoy:** No es un ERP financiero (no gestiona nómina ni Fondos de Servicios Docentes), no administra compras ni inventario físico escolar y no reemplaza los sistemas contables del Estado.

Q-PROD-02: ¿Está PEVN desplegada nacionalmente en este momento?

- **Respuesta Factual: NO.** La plataforma se encuentra desarrollada, probada y congelada en su línea base de software en un entorno local y de pruebas integradas. No opera actualmente en servidores de producción gubernamentales ni atiende colegios en vivo a nivel nacional.

Q-PROD-03: ¿PEVN reemplaza al SIMAT o al DUE/DANE?

- **Respuesta Factual: NO los reemplaza.** PEVN incorpora estructuras de datos y reglas de negocio compatibles con el modelo de matrícula correspondiente y se encuentra arquitectónicamente preparada para una eventual interoperabilidad, sujeta a las interfaces técnicas oficiales, autorizaciones y acuerdos institucionales que determine la entidad competente. No reemplaza al SIMAT, al DUE ni a los sistemas del DANE, sino que armoniza con los catálogos y directrices rectoras del Estado.

Q-PROD-04: ¿Puede un colegio público utilizar PEVN hoy en día?

- **Respuesta Factual:** El software está técnicamente listo para operar. Para que un colegio lo utilice en el mundo real, la entidad gubernamental (Ministerio o Secretaría de Educación) debe proveer el servidor de alojamiento (nube o centro de datos oficial), configurar los dominios web institucionales y formalizar los términos de tratamiento de datos personales.

---

2. Categoría: TECNOLOGÍA Y ARQUITECTURA (Technology)

Q-TECH-01: ¿Qué tecnologías se utilizaron en el desarrollo de PEVN y por qué?

- **Respuesta Factual:**
- **Backend:** Python 3.12 con FastAPI (asíncrono, tipado estricto, alto rendimiento, documentación OpenAPI v3 automática) y SQLAlchemy 2.0 Async con **asyncpg**.
- **Frontend:** React 18 con TypeScript y Vite (interfaz Single Page Application rápida, accesible y desacoplada) y Tailwind CSS.

- **Base de Datos:** PostgreSQL 16 (motor relacional empresarial ACID de código abierto con soporte avanzado de JSONB y transacciones robustas).
- **Caché y Colas:** Redis 7 (para gestión de sesiones concurrentes y caché volátil).
- **Justificación:** Se seleccionaron tecnologías de código abierto de amplia adopción global, garantizando que el Estado colombiano no dependa de licencias propietarias ni de un único proveedor de soporte.

Q-TECH-02: ¿Es escalable la arquitectura de PEVN?

- **Respuesta Factual: Arquitectónicamente SÍ.** El backend es *stateless* (sin estado en servidor), lo que permite añadir réplicas detrás de un balanceador de carga; el frontend compila a archivos estáticos distribuibles en CDN y la base de datos está particionada lógicamente por `institution_id`.
- **Validación Empírica: Aún no se han ejecutado pruebas de estrés masivas (load testing) a escala masiva concurrente.** Esta validación es una condición pendiente que debe realizarse en la fase piloto.

Q-TECH-03: ¿Cuál es la infraestructura actual de PEVN?

- **Respuesta Factual:** Actualmente opera sobre contenedores Docker locales (FastAPI, React Vite, PostgreSQL 16 y Redis 7) utilizados para la verificación funcional y la ejecución de las 432 pruebas automatizadas.

---

3. Categoría: CIBERSEGURIDAD Y CONTROL DE ACCESO (Security)

Q-SEC-01: ¿Cómo se protegen las contraseñas de los usuarios?

- **Respuesta Factual:** Se utiliza **Argon2id** (RFC 9106) con parámetros criptográficos de alta robustez: coste de memoria de 64 MB (65.536 KiB), 3 iteraciones de tiempo, paralelismo de 4 hilos y salt criptográfico aleatorio único de 16 bytes por contraseña. Es altamente resistente a ataques por fuerza bruta, GPU y tablas arcoíris.

Q-SEC-02: ¿Cómo se protegen las sesiones y los tokens JWT?

- **Respuesta Factual:**

1. El Access Token JWT tiene una caducidad de 15 minutos y reside **exclusivamente en la memoria volátil de JavaScript de React**. No se guarda en `localStorage` ni `sessionStorage`, como medida de mitigación frente al robo persistente de credenciales mediante XSS.
2. Los Refresh Tokens se entregan en cookies `HttpOnly`, `SameSite=Strict`, `Path=/api/v1/auth`, `Secure` (en producción) con ciclo de 7 días.
3. **Detección de Replay:** Cada refresco emite un nuevo token. Si un atacante intenta reutilizar un token anterior, el sistema invalida inmediatamente toda la familia de tokens (`family_id`), revoca la sesión y genera un log de auditoría crítico.

Q-SEC-03: ¿Cómo se implementa el aislamiento multi-inquilino y la protección Anti-IDOR?

- **Respuesta Factual:** Todas las consultas en la base de datos exigen el filtro `institution_id` extraído del token JWT verificado en el servidor. Si un usuario manipula identificadores UUID en URLs para consultar datos de otro colegio o de un estudiante ajeno, el backend responde `404 Not Found` **(Blind 404)** en lugar de 403, imposibilitando al atacante determinar si el registro existe en otra institución.

Q-SEC-04: ¿Qué información se registra en la auditoría inmutable?

- **Respuesta Factual:** La tabla `audit_logs` en PostgreSQL registra eventos críticos (inicios de sesión, bloqueos, cambios de notas, confirmaciones de lectura de circulares, aperturas y cierres de período) con fecha UTC tomada del reloj del motor de base de datos (`clock_timestamp()`), usuario actuante, IP, User-Agent y UUID de correlación.
- **Censura de Seguridad (Zero-Secrets):** La función `sanitize_audit_metadata()` censura de forma recursiva y automática cualquier contraseña, token, secreto o cookie con `[REDACTED]`.

Q-SEC-05: ¿Se han realizado pruebas de penetración (*Ethical Hacking*) externas?

- **Respuesta Factual: NO.** El código cumple con las reglas estáticas de Bandit y directrices OWASP ASVS v4.0, pero **la auditoría formal de penetración de caja negra por parte de una firma de ciberseguridad independiente es un requerimiento pendiente** previo a la salida a producción. No se identificaron vulnerabilidades críticas dentro del alcance de la auditoría técnica realizada.

---

4. Categoría: DATOS Y MENORES DE EDAD (Data Protection)

Q-DAT-01: ¿Quién sería el responsable y custodio de los datos en una operación real?

- **Respuesta Factual:** Esta es una **decisión institucional que debe definir el Estado colombiano**. Técnicamente PEVN soporta ambos esquemas:
- Esquema Centralizado: El Ministerio de Educación Nacional actúa como "Responsable del Tratamiento" a nivel nacional.
- Esquema Descentralizado: Cada Secretaría de Educación o cada Institución Educativa actúa como "Responsable" de los datos de su comunidad, operando PEVN como infraestructura pública.

Q-DAT-02: ¿Cómo se manejan los datos de niñas, niños y adolescentes?

- **Respuesta Factual:** En estricto apego a la Ley 1581 de 2012 y el Código de la Infancia y la Adolescencia (Ley 1098 de 2006):
- Los datos de los menores solo son visibles para sus directivos, docentes asignados y sus propios padres/acudientes acreditados.
- Las anotaciones del observador de convivencia tienen reserva legal estricta.
- Cero venta, compartición o comercialización de datos; la plataforma no incorpora rastreadores comerciales ni analítica de terceros.

Q-DAT-03: ¿Cuenta PEVN con certificación jurídica formal de la SIC o MinTIC?

- **Respuesta Factual: NO.** La plataforma fue construida aplicando los estándares técnicos de la ley, pero **la certificación formal de cumplimiento de protección de datos debe ser tramitada por la entidad pública receptora** ante la Superintendencia de Industria y Comercio al momento de formalizar el sistema de información.

---

5. Categoría: INTEGRACIÓN E INTEROPERABILIDAD (Integration)

Q-INT-01: ¿Se integra actualmente con el SIMAT en tiempo real?

- **Respuesta Factual: NO en tiempo real mediante API en vivo.** PEVN incorpora estructuras de datos y reglas de negocio compatibles con el modelo de matrícula correspondiente y se encuentra arquitectónicamente preparada para una eventual interoperabilidad, sujeta a las interfaces técnicas oficiales, autorizaciones y acuerdos institucionales que determine la entidad competente. Actualmente la carga de datos opera mediante ingesta y exportación de archivos estructurados.

Q-INT-02: ¿Soporta inicio de sesión único (SSO) con Gov.co o Carpeta Ciudadana?

- **Respuesta Factual: Actualmente NO.** La plataforma utiliza autenticación local segura con Argon2id. La integración con la pasarela OpenID Connect de Gov.co es una funcionalidad arquitectónicamente viable pero pendiente de desarrollo en fases posteriores.

Q-INT-03: ¿Cuál es el estado real de las aulas virtuales con BigBlueButton?

- **Respuesta Factual: La capa de software está completamente construida y probada** (adaptador `BBBAdapter`, firma SHA-1/256, telemetría y reproductor con proveedor simulado Mock). Sin embargo, **NO existe infraestructura física de BigBlueButton comisionada actualmente**. Para clases en vivo, la entidad receptora debe desplegar los servidores físicos BBB y el relay Coturn TURN.

---

6. Categoría: ESCALABILIDAD Y RENDIMIENTO (Scale)

Q-SCA-01: ¿Cuántos estudiantes y docentes puede soportar la plataforma?

- **Respuesta Factual:** No se proporcionan cifras de concurrencia ficticias. La arquitectura está diseñada para permitir escalamiento horizontal; la capacidad efectiva a escala nacional deberá determinarse mediante pruebas de carga y validación de infraestructura en la fase piloto.

Q-SCA-02: ¿Qué cuellos de botella existen actualmente para una escala nacional?

- **Respuesta Factual:** Se han identificado con total transparencia en el Registro de Escalabilidad:

1. Necesidad de interponer **PgBouncer** para no saturar las conexiones de PostgreSQL bajo miles de usuarios.
2. Migrar el almacenamiento de archivos desde el disco local hacia **S3 / MinIO**.
3. Desplegar un clúster de múltiples servidores BigBlueButton mediante el balanceador **Scalelite**.

---

7. Categoría: DESPLIEGUE Y FASE PILOTO (Deployment)

Q-DEP-01: ¿Qué se requiere exactamente para iniciar una prueba piloto en 5 a 10 colegios?

- **Respuesta Factual:**

1. **Servidor Web/API + Base de Datos:** 1 instancia en nube (8 vCPU, 32 GB RAM, 200 GB SSD).
2. **Servidor BigBlueButton:** 1 máquina física dedicada Ubuntu 22.04 (16 vCPU, 32 GB RAM, 500 GB NVMe, 1 Gbps) con Coturn en TCP 443.
3. **Enlaces DNS:** Subdominios oficiales del tipo `piloto.pevn.gov.co`.
4. **Certificados SSL:** Let's Encrypt o corporativos.
5. **Costo Estimado de Infraestructura:** Entre **$285 y $455 USD mensuales**.

---

8. Categoría: DONACIÓN Y TRANSFERENCIA TECNOLÓGICA (Donation)

Q-DON-01: ¿Qué se le está ofreciendo exactamente al Estado colombiano?

- **Respuesta Factual:** Se presenta una **propuesta técnica de donación y transferencia tecnológica** de los activos de software bajo la licencia de código abierto **Apache License, Version 2.0**, sujeta a revisión jurídica y a los acuerdos institucionales que determine la entidad competente. La propuesta no constituye un contrato vinculante.
- **Qué Recibiría el Estado:**
- 100% del código fuente del backend y frontend sin restricciones.
- Los 23 scripts de migración y esquemas de base de datos en PostgreSQL.
- La totalidad de la documentación de arquitectura, seguridad y operabilidad.
- Las suites completas de pruebas automatizadas (432 pruebas backend).
- **Régimen Económico: CERO PESOS ($0 COP) por licencias de software.** El Estado no pagará regalías ni suscripciones por estudiante. Los únicos costos serán los servidores de infraestructura y el personal humano de soporte que la entidad receptora decida contratar o asignar.

Q-DON-02: ¿Qué responsabilidades asumiría una entidad pública en caso de adoptar la plataforma?

- **Respuesta Factual:** La entidad pública asumiría la responsabilidad de proveer los servidores donde se aloje el sistema, custodiar las copias de respaldo de las calificaciones oficiales y garantizar la atención de soporte técnico a su comunidad educativa.